1 · Güvenlik temelleri

Zafiyet, tehdit modeli ve güvenli tasarım

Kavram	Anlamı ve sınırı
Hata · Zafiyet · İstismar	Bug (hata): yazılımın beklenen davranıştan sapması. Vulnerability (zafiyet): güvenlik etkisi doğuran zayıflık. Exploit (istismar): zafiyeti kullanma yöntemi veya kodu.
Tehdit · Risk · Etki	Threat (tehdit): zarara yol açabilecek durum veya eylem. Risk: kayıp olasılığı ve etkisinin değerlendirilmesi. Impact (etki): gerçekleşen olayın zararı.
Saldırı yüzeyi / Attack surface · Güven sınırı / Trust boundary	Erişilebilen girişler / farklı güven düzeyleri arasındaki geçiş. Veri sınırı aşınca yeni bağlamda denetlenir.
CIA	Confidentiality (gizlilik), Integrity (bütünlük), Availability (kullanılabilirlik).
CVE / CWE / CVSS	Common Vulnerabilities and Exposures (Yaygın Zafiyetler ve Maruziyetler): zafiyet kaydı. Common Weakness Enumeration (Yaygın Zayıflık Sınıflandırması): zayıflık türü. Common Vulnerability Scoring System (Yaygın Zafiyet Puanlama Sistemi): teknik şiddet puanı.
CTF · Bayrağı yakala	Capture The Flag: izinli ortamda güvenlik görevleri.

Kod incelerken

Girdinin kaynağını, ulaştığı kaynağı ve güven sınırını belirle. Hatalı varsayımı, güvenlik etkisini ve düzeltmeyi göster; aynı denemeyi düzeltmeden sonra tekrarla.

İlke	Uygulamadaki karşılığı
Least privilege · en az yetki	Uygulama ve servis hesabı yalnız gereken kaynaklara erişir.
Fail-safe defaults · güvenli varsayılan	İzin açıkça tanımlı değilse erişim reddedilir.
Complete mediation · tam denetim	Önemli her erişimde karar yeniden uygulanır. Arayüzde düğmeyi gizlemek yeterli olmaz.
Defense in depth · katmanlı savunma	Bir kontrol aşılırsa diğerleri etkiyi sınırlayabilir. Ağ kontrolü, uygulamadaki zafiyeti düzeltmez.
Open design · açık tasarım	Güvenlik algoritmanın gizli kalmasına dayanmaz; anahtarlar korunur.

STRIDE · Tehdit modelleme / Threat modeling

S **Spoofing**
Kimliğe bürünme
Bob'un oturumunu ele geçirip kullanmak.

T **Tampering**
İzinsiz değiştirme
Fatura tutarını 100'den 900'e çevirmek.

R **Repudiation**
İşlemi inkâr
Onayı kimin verdiğinin gösterilememesi.

I **Information Disclosure**
Bilgi ifşası
Başka şirketin faturasını okumak.

D **Denial of Service**
Hizmet engelleme
Ağır isteklerle servisi kullanılamaz hâle getirmek.

E **Elevation of Privilege**
Yetki yükseltme
Üye hesabıyla yönetici işlemini çalıştırmak.

2 · Injection ve dosya yolları

Enjeksiyon / Injection · Dizin dışına çıkma / Path traversal

Terim / açılım	Nerede ortaya çıkar? · Temel kontrol
SQLi · SQL enjeksiyonu / SQL Injection	Girdi, SQL (Structured Query Language · Yapılandırılmış Sorgu Dili) sorgusunun yapısını değiştirir. Değerler parametreyle; sütun gibi yapısal seçimler izin listesiyle verilir.
Komut enjeksiyonu / Command injection	`name=alice; echo DEMO` shell metnine eklenirse ikinci komut çalışabilir. Sabit programı ayrı argümanlarla çağır: `subprocess.run(["/usr/bin/echo", "Hello", name])`.
Argüman enjeksiyonu / Argument injection	Girdi `--help` gibi bir program seçeneği olabilir. Argüman listesi shell'i kaldırır; programın seçenek kuralları ayrıca denetlenir.
Dizin dışına çıkma / Path traversal	`../` ile izin verilen klasörün dışına ulaşma. Dosya açmadan önce çözümlenen yolun izinli kök içinde kaldığını denetle.
LFI · Yerel dosya dahil etme / Local File Inclusion	Sunucudaki bir dosyanın denetimsiz biçimde uygulamaya dahil edilmesi. Dosya içeriği yanıta sızabilir; içerik ve yorumlayıcıya göre kod da çalışabilir.

SQLi: aynı sorgu, değişen koşul / Changed query condition

Örnek tablo: `users` içinde `(1, Alice)` ve `(2, Bob)` var. Aşağıdaki değer URL'den çözümlenmiş `id` parametresidir.

Girdi / Input
id = 1 OR 1=1

→

Sorgu / Query
WHERE id = 1 OR 1=1
Koşul her satırda doğru.

→

Sonuç / Result
Alice + Bob
İki kayıt da döner.

```
# Hatalı / Vulnerable: girdi sorgu metnine ekleniyor.
q = "SELECT name FROM users WHERE id = " + user_id
# Güvenli / Safe: aynı girdi tek bir değer olarak bağlanıyor.
rows = db.execute("SELECT name FROM users WHERE id = ?", (user_id,))
```

Parametreli sürümde `1 OR 1=1`, SQL operatörü olmaz; bu örnekte hiçbir kullanıcı kimliğiyle eşleşmez.

LFI: sayfa seçimi dosya yoluna dönüşür / File inclusion

```
// Hatalı PHP örneği / Vulnerable PHP example: view.php
include(__DIR__ . "/pages/" . $_GET["page"]);
// İstek / Request: /view.php?page=../private/note.txt
```

İstenen sayfa / Page
../private/note.txt

→

Dosya yolu / File path
/app/pages/../private/note.txt

→

Dahil edilen / Included
/app/private/note.txt
pages/ klasörü dışında.

Örnekte `note.txt` düz metindir; içeriği yanıta eklenir. Düzeltme: kullanıcıdan dosya yolu alma; `help` gibi bir anahtarı önceden tanımlı dosyaya eşleştir. Tanımsız anahtarı reddet. Bu senaryoda path traversal, LFI'nin izinli klasör dışına ulaşmasını sağlar.

3 · HTTP, tarayıcı ve oturum

İstek / Request · Yanıt / Response · Çerez / Cookie

Terim / açılım	Hatırlanacak nokta
HTTP / HTTPS / TLS	Hypertext Transfer Protocol (Hiper Metin Aktarım Protokolü) / HTTP over TLS (TLS üzerinden HTTP) / Transport Layer Security (Taşıma Katmanı Güvenliği).
Adres / URL · Köken / Origin · Site	Uniform Resource Locator (Birörnek Kaynak Konumlayıcı). Origin = scheme (şema) + host (sunucu adı) + port. Aynı site içindeki iki alt alan farklı origin olabilir.
Çerez / Cookie · Oturum / Session	Çerez tarayıcıda tutulan ve kapsamına göre gönderilen veridir. Oturum kaydı sunucuda veya imzalı çerezde olabilir. İmzalı veri, şifreli veri anlamına gelmez.
Web depolama / Web storage	localStorage (yerel depolama) ve sessionStorage (sekme oturumuna bağlı depolama) JavaScript'ten okunabilir; HTTP isteğine otomatik eklenmez.
XSS · Siteler arası betik çalıştırma / Cross-Site Scripting	Girdi tarayıcıda kod olarak çalışır. Reflected (yansıtılan): yanıta eklenir. Stored (kalıcı): saklanır, sonraki ziyaretçide çalışır. Metin için `textContent`; HTML çıktısında bağlama uygun kodlama kullanılır.

HTTP çerez bayrakları ve öznitelikleri / Cookie flags and attributes

```
Set-Cookie: sid=abc123; Secure; HttpOnly; SameSite=Lax
```

Bayrak / öznitelik	Tarayıcının uyguladığı kural
Secure · Güvenli aktarım bayrağı	Çerez güvenli bağlantıda (genellikle HTTPS) gönderilir. Çerezin içeriğini ayrıca şifrelemez.
HttpOnly · Betik erişimi kısıtı	`document.cookie` gibi JavaScript API'leri çerezi okuyamaz. Tarayıcı uygun isteklere çerezi yine ekler.
SameSite · Siteler arası gönderim	Strict: yalnız aynı site bağlamı. Lax: buna ek olarak üst düzey, güvenli metotlu gezinmeler. None: siteler arası gönderime izin verir; Secure gerekir.

HTTP durum kodları / HTTP status codes

1xx	**Bilgilendirme** Informational	100 Continue — Devam et
2xx	**Başarılı** Successful	200 OK — Başarılı · 201 Created — Oluşturuldu 204 No Content — Yanıt gövdesi yok
3xx	**Yönlendirme** Redirection	303 See Other — Diğer adrese GET ile git 304 Not Modified — Temsil değişmedi
4xx	**İstemci hatası** Client Error	400 Bad Request — Bozuk istek · 404 Not Found — Bulunamadı 409 Conflict — Çakışma · 429 Too Many Requests — Çok fazla istek
5xx	**Sunucu hatası** Server Error	500 Internal Server Error — İç hata · 503 Service Unavailable — Hizmet yok 502 Bad Gateway — Geçersiz yanıt · 504 Gateway Timeout — Zaman aşımı

İstek / Request GET /admin	→ Kimlik bilgisi yok / No credentials →	**401 Unauthorized** Geçerli kimlik bilgisi gerekli
İstek / Request GET /admin	→ Alice: yönetici değil / Not an admin →	**403 Forbidden** Erişim yasak

4 · Uygulamalı kriptografi

Kodlama, şifreleme, özet ve imza

Yöntem / açılım	Sağladığı özellik ve dikkat noktası
Kodlama / Encoding · Base64 / Base64url	Gösterimi değiştirir; anahtar (key) gerektirmez. Gizlilik veya bütünlük sağlamaz.
Simetrik şifreleme / Symmetric encryption · AES	Advanced Encryption Standard (Gelişmiş Şifreleme Standardı). Şifreleme ve çözmede aynı gizli anahtar (secret key) kullanılır.
Asimetrik yöntemler / Asymmetric methods	Açık anahtar (public key) / özel anahtar (private key) çifti. RSA-OAEP: şifreleme (encryption); Ed25519: imza (signature); Diffie–Hellman ve X25519: anahtar anlaşması (key agreement).
Özetleme / Hashing · SHA-256	Secure Hash Algorithm (Güvenli Özet Algoritması), 256 bit. Tek yönlü özet (hash). Güvenilir kaynaktaki özetle karşılaştırma değişikliği saptayabilir.
HMAC · Anahtarlı mesaj doğrulama	Hash-based Message Authentication Code (Özet Tabanlı Mesaj Doğrulama Kodu). İçeriği gizlemez; aynı anahtarı bilenler doğrulama etiketi (tag) üretebilir.
Dijital imza / Digital signature	Özel anahtar imzalar, açık anahtar doğrular. Açık anahtarın kime ait olduğu ayrıca belirlenir.
RNG / PRNG / CSPRNG	Random Number Generator (Rastgele Sayı Üreteci) / Pseudorandom Number Generator (Sözde Rastgele Sayı Üreteci) / Cryptographically Secure PRNG (Kriptografik Olarak Güvenli PRNG). Sabit tohum (seed) ile çalışan `random`, güvenlik token'ı için uygun değildir.
Tek kullanımlık değer / Nonce · Tuz / Salt	Nonce: number used once; yöntemin tekrar etmeme kuralına tabi değer. Salt: parola kaydını farklılaştıran değer. Gizli olmaları gerekmez.

Güvenli rastgelelik ve aday sayısı

```
import secrets
reset_token = secrets.token_urlsafe(32)  # 32 bayt rastgelelik
nonce = secrets.token_bytes(12)          # AES-GCM örneği
```

Eşit olasılıkla üretilen L uzunluğunda, A sembollü bir değer için aday sayısı N = A^L. Sabit deneme hızı r ise tam tarama süresi yaklaşık N/r, rastgele hedefte ortalama yaklaşık yarısıdır. 4 rakamlı PIN'in SHA-256 özeti de yalnız 10.000 PIN adayından biridir.

Gökkuşağı tablosu (rainbow table), özet ve indirgeme (reduction) zincirleriyle ön hesaplama/bellek takası yapar. Salt, aynı ön hesabın bütün kayıtlarda kullanılmasını engeller. Parola için ayrıca Argon2id gibi maliyetli bir parola özetleme yöntemi gerekir.

5 · Parola ve kimlik doğrulama

Deneme saldırıları, güvenli saklama ve MFA

Terim / açılım	Ayırıcı özellik
Kimlik doğrulama / Authentication · Yetkilendirme / Authorization	Hangi hesap olduğunu doğrulamak ve hangi işlem/kaynağa erişebileceğine karar vermek ayrı kontrollerdir.
Kaba kuvvet / Brute force · Sözlük / Dictionary · Maske / Mask	Aday uzayını tarama / sözlükten aday seçme / bilinen biçime göre aday üretme.
Parola püskürtme / Password spraying	Çok hesaba az sayıda yaygın parola deneme. Yalnız hesap başına kilit yeterli olmayabilir.
Çalıntı kimlik bilgisi denemesi / Credential stuffing	Başka hizmetten çalınan kullanıcı adı–parola çiftlerini deneme. Tekrar kullanılmayan parolalar ve MFA etkiyi sınırlar.
Hesap varlığı tespiti / User enumeration	Mesaj, süre veya yanıt farkıyla hesabın varlığını öğrenme. Tutarlı hata yanıtı ve kontrollü işlem yolu gerekir.
Çevrim içi / Online · Çevrim dışı / Offline	Giriş noktasında deneme / ele geçmiş özet üzerinde yerel deneme. İstek hızı sınırı (rate limiting), çevrim dışı denemeyi durdurmaz.
Parola özetleme / Password hashing · Argon2id / bcrypt	Maliyetli parola özetleme yöntemleri. Tuz (salt) ve maliyet (cost) ayarı kayıtta tutulur. Hızlı SHA-256 tek başına parola saklama yöntemi değildir.
MFA / TOTP	Multi-Factor Authentication (Çok Faktörlü Kimlik Doğrulama) / Time-based One-Time Password (Zaman Tabanlı Tek Kullanımlık Parola). TOTP'de süre ve tekrar kullanım denetlenir.

Kimlik doğrulama faktörleri / Authentication factors

Faktör / Factor	Örnek / Example
Bildiğin bir şey / Something you know	Parola veya PIN: kullanıcının bildiği bilgi.
Sahip olduğun bir şey / Something you have	Güvenlik anahtarı veya doğrulama uygulamasının kurulu olduğu telefon: kullanıcının elindeki araç.
Olduğun bir şey / Something you are	Parmak izi veya yüz gibi biyometrik özellik.

MFA, en az iki farklı gruptan faktör kullanır: parola + güvenlik anahtarı gibi. İki ayrı parola aynı gruptadır. Geçiş anahtarında (passkey), cihazda veya güvenlik anahtarında tutulan kriptografik anahtar kullanılır. Cihaz PIN'i veya biyometri bu anahtarı yerel olarak kullanıma açabilir.

Uygulamada

NIST SP 800-63B-4: tek faktörlü parola en az 15 karakter; MFA parçası olduğunda en az 8 karaktere izin verilebilir. Uzun parolalar desteklenir; yaygın/sızmış değerler engellenir. Karakter türü zorlaması ve ihlal belirtisi olmadan dönemsel değişim istenmez. Parola yöneticileri ve yapıştırma desteklenir.

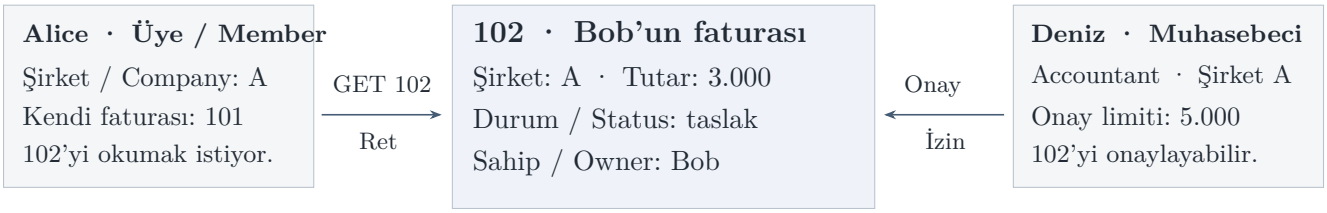
Girişlerde hesap, ağ ve genel trafik bağlamında deneme sınırı; tutarlı hata mesajı; yok hesap için maliyetli doğrulama yolu; başarıdan sonra yeni oturum gerekir. Hesap kilidinin hizmet engellemeye dönüşebileceği de düşünülür.

Parola sıfırlama (password reset): CSPRNG ile üretilmiş token; kullanıcıya bağlı, kısa ömürlü ve tek kullanımlık kayıt. Token loglanmaz. Bilgi hırsızı yazılım (infostealer), parolayı veya hazır oturumu kopyalayabilir; MFA her oturum hırsızlığını önlemez.

6 · Yetkilendirme

Tek vaka: aynı faturada kayıt, işlem ve alan izinleri

A şirketinde Alice ve Bob üye, Deniz muhasebecidir. Üyeler kendi veya düzenleyici olarak paylaşılan faturaları okur, notlarını değiştirir. Muhasebeci aynı şirketteki, limiti içindeki taslak faturayı onaylayabilir.



Kontrolün yeri	Aynı vakada ne olur?
IDOR / BOLA	Insecure Direct Object Reference (Güvensiz Doğrudan Nesne Referansı) / Broken Object Level Authorization (Nesne Düzeyinde Yetkilendirme Eksikliği). Alice, `GET /invoices/101` yerine `GET /invoices/102` gönderir. İzni yokken Bob'un faturası dönüyorsa nesne erişimi hatalıdır; bu örnekte iki ad aynı sorunun farklı yönlerini anlatır.
BFLA	Broken Function Level Authorization (İşlev Düzeyinde Yetkilendirme Eksikliği). Alice, `POST /invoices/101/approve` çağırır. Fatura kendisinin olsa da onay rolü yoktur; işlem reddedilmelidir.
BOPLA	Broken Object Property Level Authorization (Nesne Alanı Düzeyinde Yetkilendirme Eksikliği). Alice 101'in notunu değiştirebilir; aynı istekte `status=approved` göndererek faturayı onaylayamaz. Toplu alan atama (mass assignment) bu sınırı aşmamalıdır.
RBAC	Role-Based Access Control (Rol Tabanlı Erişim Kontrolü). Deniz'in muhasebeci rolü onay işlevine erişim sağlar. Alice'in üyeliği sağlamaz.
ABAC	Attribute-Based Access Control (Öznitelik Tabanlı Erişim Kontrolü). 102 aynı şirkette, 3.000 tutarı 5.000 limitinin altında ve taslak durumunda: Deniz'in onay koşulları sağlanır.
ReBAC	Relationship-Based Access Control (İlişki Tabanlı Erişim Kontrolü). Bob, Alice'i 102'ye düzenleyici olarak eklerse Alice notu değiştirebilir. Bu paylaşım onay yetkisi vermez.

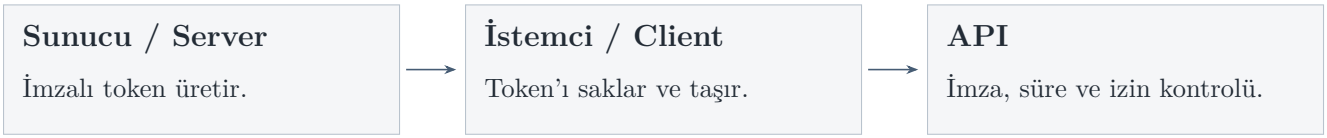
Her işlem için gereken kontroller birlikte uygulanır. UUID (Universally Unique Identifier · Evrensel Benzersiz Tanımlayıcı) kullanmak bu izinleri sağlamaz. Okuma, not değiştirme ve onay için farklı kararlar verilebilir.

7 · JWT, OAuth, SSO ve loglama

Token'ın yolculuğu, ortak giriş ve kayıttan alarma

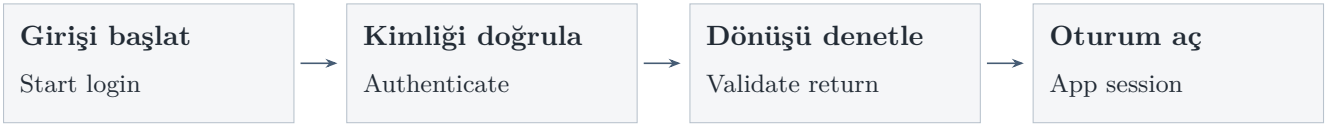
Kavram / Concept	Kısa karşılığı
JWT / JWS / JWE	JSON Web Token (JSON Web Belirteci); JSON Web Signature (JSON Web İmzası); JSON Web Encryption (JSON Web Şifrelemesi). İmzalı JWT'nin içeriği okunabilir.
Simetrik / Symmetric · Asimetrik / Asymmetric	HS256: üreten ve doğrulayan hizmet aynı gizli anahtarı bilir. RS256: özel anahtar (private key) imzalar; açık anahtar (public key) doğrular.
OAuth / OIDC / SSO	OAuth 2.0 Authorization Framework (Yetkilendirme Çerçevesi): API yetkisi. OpenID Connect: kimlik doğrulama. Single Sign-On (Tek Oturum Açma): bir girişle birden çok uygulama.
Access / ID / Refresh token	Erişim / kimlik / yenileme token'ı: API isteği / giriş sonucu / yeni erişim token'ı alma. ID token API'ye erişim belgesi değildir.
PKCE / state / nonce	Proof Key for Code Exchange (Kod Değişimi için İspat Anahtarı): kodu istemciye bağlar. State (işlem durumu) dönüşü giriş denemesiyle eşleştirir. Nonce (tek kullanımlık değer), ID token'ı isteğe bağlar.
iss / sub / aud / exp	Issuer (üretici) / Subject (özne) / Audience (alıcı) / Expiration Time (bitiş zamanı). API imza, üretici, alıcı ve süreyi; sonra nesne/işlem iznini kontrol eder.

1 · JWT nerede durur? / Token flow



Token istemcide saklanıp istekle gönderilir. HttpOnly çerez ve JavaScript depolarının riskleri farklıdır. Gizli/özel anahtar istemciye verilmez. Sunucu gerektiğinde hesap ve iptal kaydı tutar.

2 · Kurumsal giriş / Corporate sign-in



Uygulama dönüşü doğrular ve kendi oturumunu açar. SSO'da ortak giriş hizmetinin açık oturumu ikinci uygulamada da kullanılabilir; uygulamaların yerel oturumları ayrıdır.

3 · Kayıttan alarma / Logs to alerts



Data parsing (veri ayrıştırma) alanları çıkarır; data visualization (veri görselleştirme) örüntüyü gösterir. ML (Machine Learning · Makine öğrenmesi), olağan düzenden sapmaları işaretleyebilir. Anomaly detection (anomali tespiti), inceleme sinyalidir; her sapma saldırı değildir.

Logda zaman, doğrulanmış kullanıcı, kaynak, sonuç ve istek kimliği bulunur. DEBUG (hata ayıklama), INFO (bilgi), WARNING (uyarı), ERROR (hata). Parola, çerez ve token kaydedilmez.

Dosya yükleme / File upload

Örnek: Görsel ekinde `Content-Type: image/jpeg` (içerik türü) yazması, dosyanın görsel olduğunu kanıtlamaz. Tür, içerik ve boyut sunucuda denetlenir. Dosya sunucunun verdiği adla web kökü dışında saklanır; yükleme ve indirmede izin aranır.

RCE · Uzaktan kod çalıştırma / Remote Code Execution



RCE etkidir; zafiyetin türü kök nedeni anlatır. Yüklenen dosyanın sunucuda kod olarak çalıştırılması RCE'ye yol açabilir. Log4Shell (CVE-2021-44228) başka bir örnektir. Kod uygulamanın hesabıyla çalışır; otomatik yönetici yetkisi sağlamaz.